

SENDERWHO - ENGINEERING TODO LIST

=====

Updated: 19 July 2026

Scope: Remaining application, integration, privacy, and security work

OUTSTANDING WORK

[] P0 - Full API E2E and cross-user IDOR/BOLA testing

Build an automated test environment using NestJS, disposable MySQL, Redis, and BullMQ. Test every authenticated object endpoint with two different users and prove that one user cannot read or modify another user's accounts, messages, senders, alerts, jobs, sessions, exports, or deletion operations.

Completion evidence:

- HTTP-level E2E tests run in CI.
- Every ID-based endpoint has an unauthorized cross-user test.
- Database, Redis, queue retry, and idempotency failure paths pass.

[] P0 - Verify real Google OAuth and Gmail operations

Use an approved Google test project and non-production test accounts to validate consent, connect, reconnect, token refresh, session restore, initial and incremental sync, worker recovery, archive, trash, restore, read/unread, bulk actions, disconnect, and provider revocation.

Completion evidence:

- Exact production-style redirect and scopes are tested.
- Gmail partial failures and expired/revoked tokens are tested.
- No production Gmail account or production data is used.

[] P1 - Implement app-level MFA

Add passkey/WebAuthn or TOTP enrollment, verification, recovery codes, secure recovery, device/session management, and step-up verification for destructive actions. Google reauthentication alone must not be described as SenderWho app-level MFA.

Completion evidence:

- Enrollment, challenge, recovery, revoke, and logout tests pass.
- Sensitive operations require a recent verified factor.
- Secrets and recovery codes are encrypted and never logged.

[] P1 - Complete the user data export download

Export every paginated section: profile, connected accounts, senders, messages, alerts, and audit history. Provide a secure cross-platform save/download/share experience with clear progress and failure recovery.

Completion evidence:

- Large multi-page exports are complete and correctly scoped.
- Android, iOS, web, macOS, and Windows delivery paths are tested.
- Temporary files and download links expire and are not publicly exposed.

[] P2 - Add explainable AI-powered anomaly detection

Design a privacy-reviewed risk engine for suspicious logins, devices, unusual velocity, bots, account takeover signals, and abnormal sender or account activity. Begin in monitor-only mode and keep deterministic rules as a safe baseline and fallback.

Completion evidence:

- Alerts include stable reason codes and model/rule versions.
- False positives, drift, thresholds, overrides, and rollback are measured.
- AI output alone never permanently blocks or deletes user data.

COMPLETED - REMOVED FROM THE TODO QUEUE

- [x] CI formatting was fixed by separating the TypeScript Prettier check from Prisma schema validation.
- [x] Security-alert detail loading and alert dismissal are connected to the UI, include busy-state protection, and have frontend/backend regression tests.
- [x] API failures no longer appear as false empty/default states on the affected screens; explicit error and retry states are implemented.
- [x] SenderWho MySQL, Redis, and Adminer are bound to 127.0.0.1 only. Current verified ports are MySQL 3307, Redis 6379, and Adminer 8080.

CURRENT LOCAL VALIDATION BASELINE

- Flutter analysis: clean.
- Flutter tests: 30 passed, 1 intentional preview skip.
- Backend lint and TypeScript build: passed.
- Backend tests: 50 passed.
- npm dependency audit: 0 known vulnerabilities at the latest local check.
- Web release, Android release, and iOS Simulator builds: passed.

IMPORTANT

Do not mark an outstanding item complete without automated evidence and a non-production integration environment. Never use production Gmail data or real customer accounts for destructive tests.